



Instituto Politécnico Nacional  
Escuela Superior de Cómputo



Ingeniería en Sistemas Computacionales  
Academia de Sistemas Distribuidos

Unidad de Aprendizaje:  
Gobierno de TI | Computer Security

Tarea 17: “Técnicas para escalar privilegios”

Luis Andrés Contla Mota

2022630540

6CV4

Profesor:

MBA. Rodrigo Ojeda Santillán

CGUI es la explotación de privilegios?

Escalación de privilegios es técnica post-explotación donde el atacante obtiene permisos superiores a los iniciales. Vertical:

usuario normal  $\rightarrow$  admin/root en mismo sistema, más crítica.

Horizontal: usuario A  $\rightarrow$  usuario B mismo nivel, extendiendo alcance.

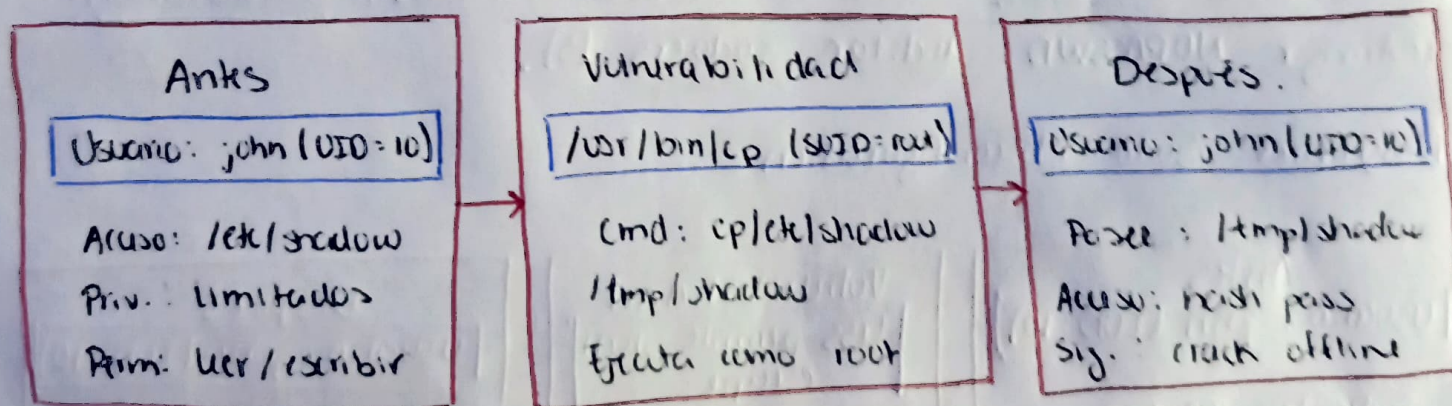
Ambas requieren vulnerabilidad o mala configuración en kernel, servicios, permisos. Fundamental en attack chain post-acceso inicial. [1][2][3].

### Linux - Técnica 1: SUID Bit Exploitation

SUID permite ejecutable correr con permisos propietario. Vulnerabilidad: binarios SUID mal programados ejecutan como root [2].

Ejemplo: /usr/bin/cp con SUID permite copiar /etc/shadow para crack offline. Detección: find /perm /4000. Remediación: minimizar SUID, auditar regularmente, usar AppArmor/SELinux.

### Diagrama SUID Bit Exploitation



### Windows - Técnica 1: Unquoted Service Path

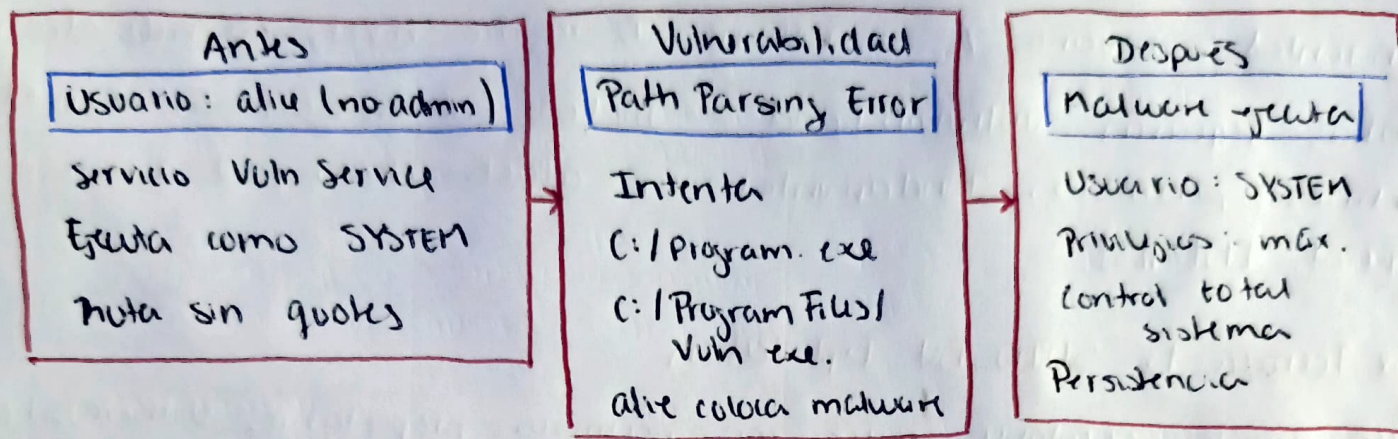
Unquoted service path: servicio sin quotes en ruta ejecutable.

Windows intenta: c:/Program.exe  $\rightarrow$  c:/ProgramFiles/Vuln.exe

$\rightarrow$  path real [2]. Ataque: colocar malware en c:/Program.exe

ejecutando como SYSTEM [1][3]. Herramienta: PowerUp.ps1 detecta [2]. Remediación: agregar quotes en ruta [3].

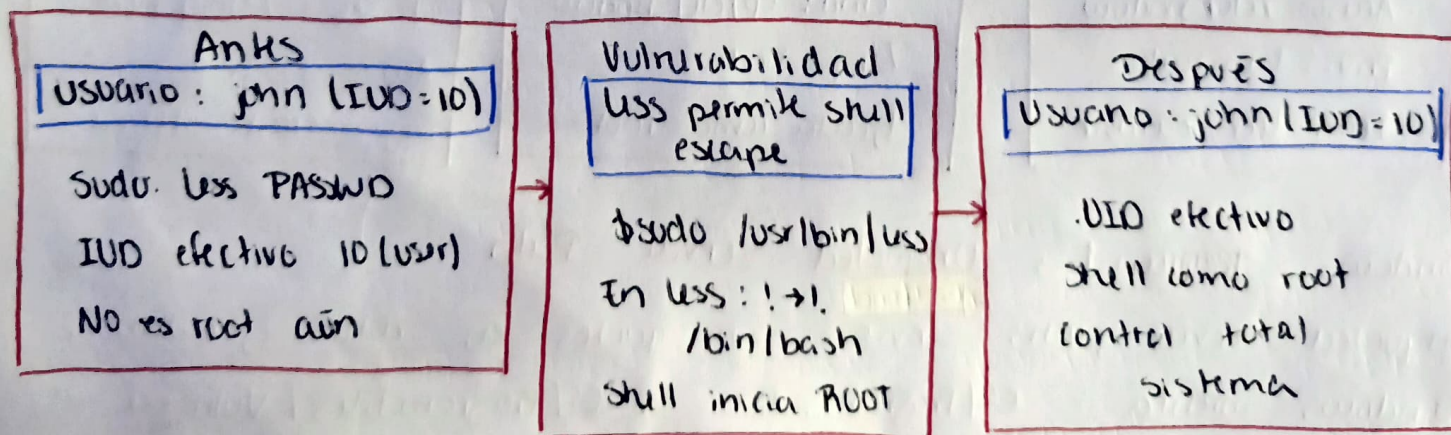
### Diagrama Unquoted Service



### Linux - Técnica 2: Sudo Misconfiguration

Sudo misconfiguration: NOPASSWD permite ejecutar sin contraseña [1]. Vulnerabilidad: comando permite shell escape (less → !/bin/bash). Ejemplo: sudo less/etc/passwd como root acceso [1][3]. Auditoria: sudo -l enumera comandos. Remediación: restringir NOPASSWD, auditar sudoers [3].

### Diagrama Sudo Misconfiguration

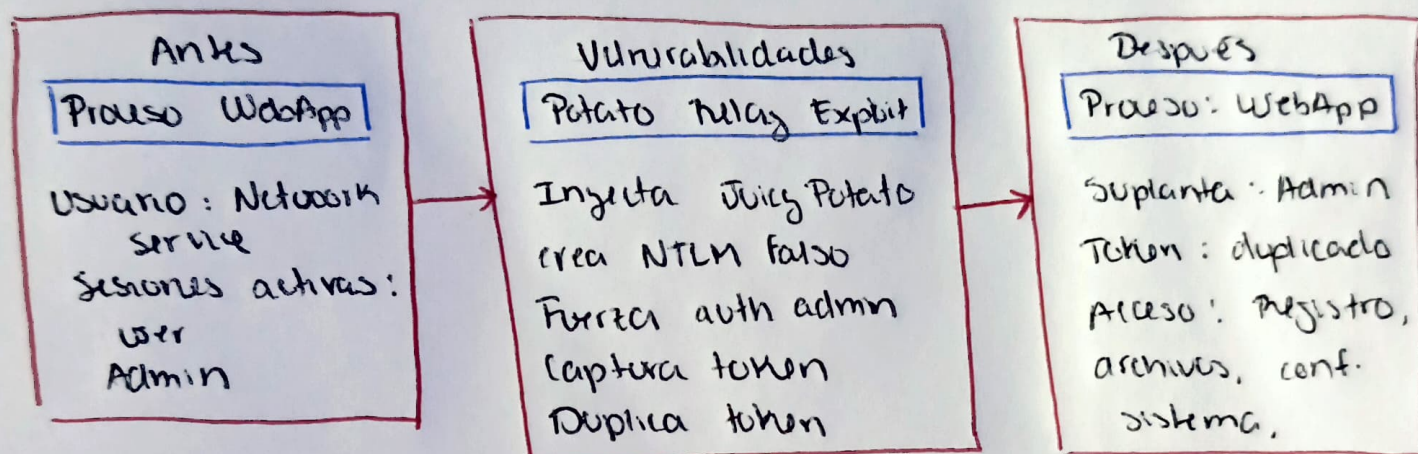


## Windows - Técnica 2: Token impersonation.

Token impersonation, proceso que accede a tokens privilegiados de usuarios conectados. [1]. Requisito: SeImpersonate privilege habilitado. Herramientas: JuicyPotato abusa NTLM relay. [2][3].

Técnica: near servidor NTLM, forzar autenticación, redirigir token privilegiado. Remediación: remover SeImpersonate, AppLocker, restringir Network Service [3].

### Diagrama Token Impersonation



### Resumen de técnicas

SUID/SUDO (Linux) explotan permisos archivos/comandos.  
Unquoted Path/tokens (Windows) abusan configuración servicios.  
Tokens requieren acceso pleno y vulnerability/misconfiguración.  
Defensa común: least privilege, auditoría regular, restricción permisos, patching. [1][2][3].

## Referencias

- [1]. MITRE ATT&CK. (2024). Privilege Escalation Techniques.  
<https://attack.mitre.org/tactics/TA0004/>
- [2]. HackTricks. (2024). Privilege Escalation. <https://book.hacktricks.xyz/>
- [3]. GTFOBins. (2024). Unix Binaries Exploitation. <https://gtfobins.github.io/>
- [4]. PowerShellEmpire. (2024). Post-Exploitation Modules.  
<https://github.com/EmpireProject/Empire>
- [5]. OWASP. (2023). Privilege Escalation Testing. <https://owasp.org/>